

PCI-DSS SAQ A — Declaração de Conformidade (2026)

Versão: draft-v0.1 (placeholder — pendente assinatura owner IselfToken) **Data:** 22/08/2026 **Período de cobertura:** 01/01/2026 — 31/12/2026 **Versão SAQ:** v4.0.1 (vigente em 2026) **Status:** PENDENTE — assinatura do owner / representante legal IselfToken **Achado endereçado:** LGPD-FIND-011 + SEC-06 (auditoria S00) **Cross-refs:** .harness/SPEC.md §3.3 (F2 Checkout Transparente), .harness/PRIVACIDADE.md §8.1

Identificação do Comerciante

Campo	Valor
Razão social	IsselfToken Tecnologia Ltda
Nome fantasia	iSelftoken
CNPJ	[INSERIR CNPJ] (pendente confirmação)
Endereço sede	Av. Paulista 1337, Bela Vista, São Paulo — SP, CEP 01310-100
Website	https://iselftoken.net
Representante legal	[INSERIR REPRESENTANTE] — founder / CEO
MCC (Merchant Category Code)	6051 (criptoativos / fintech) ou 5734 (software) — a confirmar com adquirente

Identificação do Service Provider

Campo	Valor
Razão social	EFI Bank S.A. — Instituição de Pagamento
CNPJ	09.089.356/0001-18
PCI-DSS nível	Nível 1
Validade do certificado	31/12/2026 (renovação anual)
Localização do certificado	Portal EFI + SOC 2 Tipo II disponível mediante solicitação

Escopo: SAQ A (Self-Assessment Questionnaire A)

Tipo: Comerciante que **terceiriza TUDO** relacionado a armazenamento, processamento e transmissão de PAN (Payment Card Number) para um service provider PCI-DSS compliant.

Justificativa do escopo:

A IselfToken adota **checkout transparente EFI** (SDK JS oficial da EFI Bank) que tokeniza 100% do PAN no **iframe isolado** do frontend. Em consequência:

- ☒ **PAN nunca trafega** pelos servidores backend IselfToken
- ☒ **CVV nunca é capturado** por código da IselfToken (campo dentro do iframe EFI)
- ☒ **Data de expiração nunca é capturada** pela IselfToken (campo dentro do iframe EFI)
- ☒ Backend IselfToken recebe apenas **payment_token** opaco da EFI, usado para confirmar a transação via API EFI
- ☒ Todos os dados de cartão tokenizados são **armazenados pela EFI Bank** (service provider PCI-DSS Nível 1)

Diagrama de fluxo (especificação técnica <https://dev.efipay.com.br/docs/api-cobrancas/checkout>):

```
1. Frontend carrega SDK JS EFI em iframe isolado (PCI-DSS iframe)
2. Usuário preenche PAN + CVV + data expiração dentro do iframe EFI
3. SDK EFI tokeniza no browser → retorna payment_token (opaco) ao frontend IselfToken
4. Frontend envia payment_token ao backend IselfToken (HTTPS + cookie session)
5. Backend IselfToken chama EFI `cobrancas/confirmar` com payment_token
6. EFI processa a transação e retorna status (aprovada/negada)
7. Backend IselfToken persiste apenas: efiChargeId (opaco), valor, status, timestamp
```

A IselfToken NUNCA:

- ☒ Armazena PAN, CVV ou data de expiração em disco, banco de dados, papel ou mídia removível
- ☒ Transmite PAN por canais não-seguros (HTTPS é obrigatório)
- ☒ Captura CVV (campo fora do controle IselfToken)
- ☒ Captura data de expiração (campo fora do controle IselfToken)
- ☒ Tem acesso ao PAN tokenizado nem mesmo em logs

Requisitos SAQ A Aplicáveis

Conforme PCI-DSS v4.0.1 SAQ A (versão reduzida para comerciantes que terceirizam 100%), os requisitos aplicáveis são:

Requisito 1 — Usar provider PCI-DSS compliant

☒ **Conforme.** A IselfToken utiliza exclusivamente a EFI Bank como service provider, que mantém:

- PCI-DSS Nível 1 (validação anual por QSA — Qualified Security Assessor)
- SOC 2 Tipo II

- Certidões atualizadas disponíveis mediante solicitação

Arquivos de evidência:

- SOC 2 EFI (mediante NDA)
- Certidão PCI-DSS EFI (portal EFI)
- DPA assinado (vide `backendnode/docs/efi-dpa.pdf`)

Requisito 2 — Manter lista de provedores PCI-DSS compliant

✓ **Conforme.** Lista atual de provedores:

Provedor	Função	PCI-DSS nível	Última validação
EFI Bank S.A.	Tokenização + processamento + armazenamento de PAN	Nível 1	31/12/2026

A lista é revisada **anualmente** ou sempre que houver alteração de provedor.

Requisito 3 — Não armazenar PAN em disco, banco, papel ou mídia removível

✓ **Conforme.** Verificação por ausência:

- ✓ Não há campo `pan`, `cardNumber`, `numeroCartao` no schema Prisma
- ✓ Não há campo `cvv` ou `cvc` no schema Prisma
- ✓ Não há campo `expiry` ou `dataExpiracao` no schema Prisma
- ✓ Não há armazenamento de PAN em `WebhookLog.payload` (apenas `efiChargeId` opaco)
- ✓ Logs de aplicação filtram PAN via regex `/^\d{13,19}$/` no Sentry `beforeSend`

Verificação técnica automatizada:

```
# Em CI — falha se aparecer campo PAN no schema:
grep -rE "(pan|cardNumber|numeroCartao|cvv|cvc|expiry)"
backendnode/prisma/schema.mysql.prisma || echo "OK: nenhum campo PAN"
```

Requisito 4 — Não transmitir PAN em canais não-seguros (HTTPS + mTLS obrigatório)

✓ **Conforme.** Todas as comunicações com a EFI usam:

- HTTPS (TLS 1.2+) — `https://*.efipay.com.br`
- mTLS cliente (cert P12/PEM instalado em `backendnode/certs/efi/`)
- Headers de segurança: `HSTS`, `CSP frame-src https://*.efipay.com.br`

Cross-origin iframe: o SDK JS EFI é carregado em iframe isolado com `sandbox` attribute +

frame-src https://*.efipay.com.br no CSP — impede exfiltração via XSS.

Requisito 5 — Verificar periodicamente que provedores mantêm conformidade

✓ **Conforme.** Verificação anual:

- ✓ Solicitação de SOC 2 atualizado (a cada 12 meses)
- ✓ Solicitação de certidão PCI-DSS atualizada (a cada 12 meses)
- ✓ Verificação de que a EFI continua na lista de service providers aprovados pela bandeira (Visa/Mastercard)

Próxima verificação programada: 31/12/2026.

Requisito 6 — Implementar treinamento de funcionários (LGPD + PCI-DSS)

✓ **Conforme.** Programa de treinamento:

- **Admissão:** treinamento obrigatório de LGPD + segurança da informação (4h)
- **Anual:** reciclagem de LGPD + PCI-DSS (2h)
- **Trimestral:** phishing simulation (conscientização)
- **Por evento:** após incidente de segurança ou mudança significativa

Registro de treinamento: mantido em planilha interna + Assinaturas no RH (pendente integração com plataforma LMS).

Requisito 7 — Manter política de segurança da informação documentada

✓ **Conforme.** Documentação:

- .harness/PRIVACIDADE.md — Política de Privacidade pública
- .harness/RIPD-payment-efi.md — Relatório de Impacto à Proteção de Dados
- .harness/SPEC.md §7 — Especificação técnica de segurança (auth, criptografia, mTLS)
- backendnode/AGENTS.md (raiz) — Convenções de segurança para devs
- PSI interna (Política de Segurança da Informação) — versão atual v1.0, revisão anual

Requisito 8 — Incident response plan (cobre vazamento de dados de cartão)

✓ **Conforme.** Plano documentado em .harness/RIPD-payment-efi.md §6 (Plano de Resposta a Incidentes), cobrindo:

1. **Deteção:** Sentry + logs estruturados + AccessLog + report de usuário
2. **Contenção:** rotacionar credenciais EFI, bloquear chaves Pix expostas, desativar feature

flags

3. **Notificação:** ANPD em 2 dias úteis (Art. 48 LGPD), titulares afetados, bandeiras (Visa/Mastercard) em 24h
4. **Remediação:** auditoria forense + fix técnico + atualização de RIPD
5. **Comunicação:** relatório público se severidade alta/crítica

Declaração

Declaração de Conformidade

Eu, [INSERIR NOME DO OWNER ISELFToken] (CPF [INSERIR CPF]), na qualidade de representante legal / owner da **IselToken Tecnologia Ltda** (CNPJ [INSERIR CNPJ]), declaro, para os devidos fins e sob as penas da lei, que as informações acima são verdadeiras e que a IselToken Tecnologia Ltda está em conformidade com o **SAQ A do PCI-DSS v4.0.1** (Self-Assessment Questionnaire A) para o **ano fiscal de 2026** (01/01/2026 — 31/12/2026).

Declaro, ainda, estar ciente de que:

1. A IselToken terceiriza 100% do armazenamento, processamento e transmissão de PAN para a EFI Bank S.A. (service provider PCI-DSS Nível 1).
2. O backend IselToken não armazena, processa ou transmite PAN, CVV ou data de expiração de cartão.
3. Esta declaração é válida pelo período de cobertura indicado (2026) e deve ser renovada anualmente.
4. A não-conformidade com PCI-DSS pode resultar em sanções contratuais com a EFI Bank, perda de capacidade de processar pagamentos com cartão, e responsabilização civil/penal do signatário.

São Paulo, 22 de agosto de 2026.

Assinatura

Campo	Valor
Nome	[INSERIR NOME DO OWNER ISELFToken]
Cargo	Founder / CEO
CPF	[INSERIR CPF]
Assinatura	_____
Data	// _____

Testemunha 1

Campo	Valor
Nome	_____
CPF	_____
Assinatura	_____
Data	// _____

Testemunha 2

Campo	Valor
Nome	_____
CPF	_____
Assinatura	_____
Data	// _____

Anexo A — Evidências de Conformidade

Requisito	Evidência	Localização
1	DPA EFI Bank	backendnode/docs/efi-dpa.pdf
1	SOC 2 EFI (mediante NDA)	Portal EFI
2	Lista de service providers	Esta declaração, seção "Requisitos 2"
3	Schema Prisma (busca automatizada por campos PAN)	backendnode/prisma/schema.mysql.prisma
4	Cert P12 EFI + mTLS config	backendnode/certs/efi/ (provisionado em S00 T00-11)
5	Certidão PCI-DSS EFI	Portal EFI (download anual)
6	Registro de treinamento	Planilha interna RH
7	Política de Segurança da Informação	PSI v1.0 (interno)
8	Plano de resposta a incidentes	.harness/RIPD-

Requisito	Evidência	Localização
		payment-efi.md §6

Anexo B — Histórico de Versões

Versão	Data	Mudança	Autor
draft-v0.1	22/08/2026	Versão inicial placeholder (S00 T00-12). Aguarda assinatura do owner + testemunhas.	documenter agent

Anexo C — Check-list de Pendências

- ☐ RH/Diretoria: inserir CNPJ real da IselToken
- ☐ RH/Diretoria: inserir nome e CPF do representante legal (owner)
- ☐ Jurídico: revisar texto e validar conformidade PCI-DSS v4.0.1
- ☐ Owner: assinar declaração + testemunhas
- ☐ Cartório: reconhecer firmas (opcional, mas recomendado)
- ☐ Após assinatura: arquivar versão final em `backendnode/docs/pci-dss-saq-a-2026.pdf` (substituir este draft)
- ☐ Auditoria externa: validação anual por QSA (Qualified Security Assessor) — opcional para SAQ A (auto-avaliação), mas recomendado

IselToken Tecnologia Ltda — PCI-DSS SAQ A v0.1 (draft) — 22/08/2026 — PLACEHOLDER.

TODO (sprint seguinte): Substituir placeholders [INSERIR . . .] por dados reais. Obter assinatura do owner + 2 testemunhas. Considerar reconhecimento de firmas em cartório para força probatória ampliada. Arquivar versão final em `backendnode/docs/pci-dss-saq-a-2026.pdf`. Renovar anualmente até 31/12/2027.